NileTech Payments

Information Security Risk Assessment

Prepared by **Ahmed Talaat**
October 2026 · Version 1.0
Fictional company · portfolio project

1 Key assets

The 17 most important things NileTech Payments must protect, who owns each one, and how critical it is.

ID	Asset	What it is	Owner	Criticality
A01	**Payment system**	Processes card payments for merchants	Engineering Manager	Critical
A02	**Customer database**	Merchant and customer details	Engineering Manager	Critical
A03	**Card data storage**	Stores protected card numbers	Security Manager	Critical
A04	**Cloud servers (AWS)**	Where all payment systems run	Engineering Manager	Critical
A05	**Merchant website**	Merchants log in to see sales and payouts	Engineering Manager	High
A06	**Company email (Microsoft 365)**	Email, files and chat for staff	IT Manager	High
A07	**Staff login system (single sign-on)**	One login for all company apps	IT Manager	Critical
A08	**Customer support system (CRM)**	Merchant sign-ups and support tickets	Support Manager	High
A09	**Employee laptops**	About 260 laptops	IT Manager	High
A10	**Backups**	Daily copies of systems and data	IT Manager	Critical
A11	**Online document storage**	Merchant ID documents and reports	Engineering Manager	High
A12	**Merchant payouts system**	Sends merchants their money daily	Finance Manager	Critical
A13	**Finance shared drive**	Finance team working files	Finance Manager	High
A14	**Security logs**	Record of who did what on our systems	Security Manager	High
A15	**HR system**	Employee records, joiners and leavers	HR Manager	High
A16	**Outsourced developers (CodeBridge)**	6 external developers working on our systems	Engineering Manager	High
A17	**Outsourced support team (SupportLink)**	40 external agents using our support system	Support Manager	High

> **Critical** = losing it stops payments or exposes card data. **High** = serious damage, but the business keeps running.

2 Risk assessment methodology

Each risk is written as **Cause → Event → Consequence**. It gets a likelihood (1–5) and an impact (1–5), and the score is **Likelihood × Impact** (1–25). Every risk is scored twice: **inherent** (if we had no controls) and **residual** (with the controls we have today).

Likelihood

#	Level	Meaning
1	Rare	Very unlikely to happen this year
2	Unlikely	Could happen, but not expected this year
3	Possible	Might happen this year
4	Likely	Will probably happen this year
5	Almost certain	Expected to happen this year

Score bands and risk appetite

Band	Score	What we do
Critical	20–25	Not acceptable. Tell the CEO in 48h; plan within 2 weeks
High	10–16	Not acceptable. Fix within 90 days
Medium	5–9	Fix if worth the cost, or owner signs to accept it
Low	1–4	Accept and check once a year

> **Risk appetite:** we accept very little risk around card data and payments being down. Anything scoring 10 or more must be treated.

Impact (use the worst realistic outcome)

#	Level	Money	Operations	Data	Legal
1	Negligible	< EGP 100K	No disruption	No sensitive data	None
2	Minor	EGP 100K-1M	Payments slow for < 1 hour	Internal data only	Internal audit note
3	Moderate	EGP 1M-5M	Payments down 1-4 hours	A few hundred customer records	External audit finding
4	Major	EGP 5M-25M	Payments down 4-24 hours	Thousands of customer records	Regulator warning or fine
5	Severe	> EGP 25M	Payments down > 1 day	Card data exposed	Licence at risk

Treatment options

Mitigate
add controls to lower the risk

Transfer
pass the cost on, e.g. insurance

Avoid
stop the risky activity

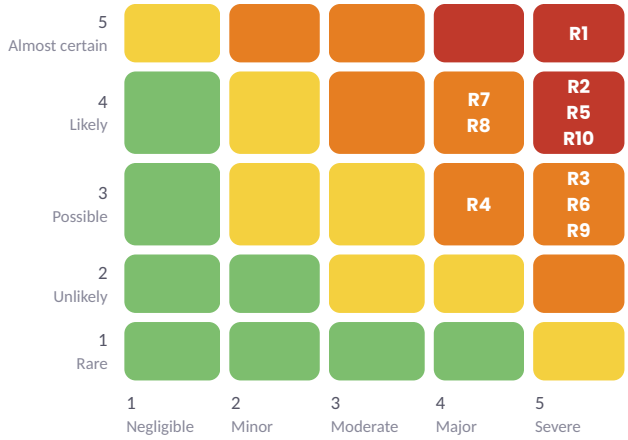
Accept
owner signs off on living with it

3 Risk register overview

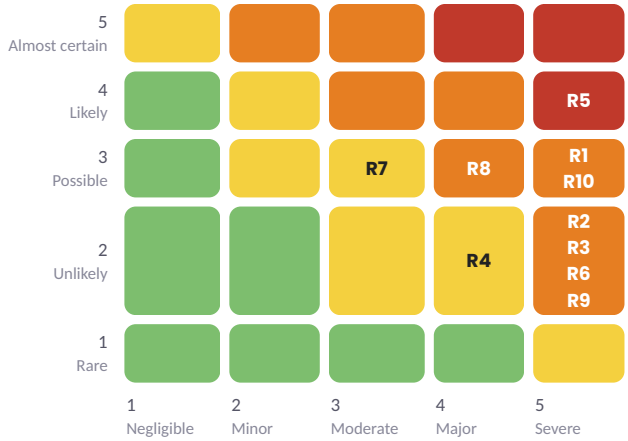
Ten risks, highest residual score first. The full details (threat, weakness, current controls, action plan, status) are in the Excel register.

ID	Risk (Cause → Event → Consequence)	Inh.	Res.	Owner	Due
R5	The outsourced developers share one permanent admin account on our cloud servers, so if they are hacked the attacker gets straight into our systems, exposing card and customer data.	20	20	Engineering Manager	15 Dec 2026
R1	Staff use basic phone-approval logins and get little training, so an employee may type their password into a fake login page, letting an attacker take over their email and see merchant data.	25	15	IT Manager	31 Mar 2027
R10	14 people have permanent full admin access and nobody reviews it, so one hacked admin account may give an attacker control of all our systems.	20	15	Security Manager	31 Jan 2027
R8	Logs are kept for only 90 days and nobody reviews them, so an attack may go unnoticed for weeks, making the damage worse and hard to investigate.	16	12	Security Manager	30 Apr 2027
R2	Updates are installed by hand once a month, so a hacker may use a known weakness on the merchant website to break in and steal data.	20	10	Engineering Manager	28 Feb 2027
R3	Backups are kept in the same place as the main systems and are never tested, so ransomware may lock both, stopping merchant payouts for days and losing data.	15	10	IT Manager	31 Jan 2027
R6	Engineers can create online storage folders without any checks, so a folder of merchant ID documents may be left public, exposing personal data and breaking data protection law.	15	10	Engineering Manager	31 Jan 2027
R9	The disaster recovery plan has never been tested, so a major cloud outage may stop payments for more than a day, leading to merchant penalties and lost customers.	15	10	CTO	30 Jun 2027
R7	Some laptops are not managed by IT and not encrypted, so a lost or stolen laptop may expose customer files and saved passwords.	16	9	IT Manager	31 Dec 2026
R4	Leavers are removed by a manual email from HR, so their accounts may stay active, letting them still see customer data after they leave.	12	8	HR Manager	31 Mar 2027

Inherent risk



Residual risk



Result: our current controls bring the average score down from 17.4 to 11.9, but **8 of 10 risks are still too high** (score 10 or more). One is Critical: **R5, outsourced developer access**.

4 Control mapping

Each risk is mapped to the ISO/IEC 27001:2022 Annex A controls that treat it. This tells an auditor *which control to check* for each risk.

ID	Asset	ISO 27001:2022 Annex A control
R1	A06 Company email; A07 Staff login system	**6.3** Information security awareness, education and training **8.5** Secure authentication
R2	A05 Merchant website; A01 Payment system	**8.8** Management of technical vulnerabilities
R3	A13 Finance shared drive; A10 Backups; A12 Merchant payouts system	**8.7** Protection against malware **8.13** Information backup **5.30** ICT readiness for business continuity
R4	A07 Staff login system; A08 Customer support system; A15 HR system	**5.16** Identity management **5.18** Access rights
R5	A16 Outsourced developers; A04 Cloud servers	**5.19** Information security in supplier relationships **5.20** Addressing information security within supplier agreements **5.21** Managing information security in the ICT supply chain **5.22** Monitoring, review and change management of supplier services
R6	A11 Online document storage	**5.23** Information security for use of cloud services **8.9** Configuration management
R7	A09 Employee laptops	**8.1** User endpoint devices **8.24** Use of cryptography
R8	A14 Security logs; A04 Cloud servers	**8.15** Logging **8.16** Monitoring activities
R9	A01 Payment system; A12 Merchant payouts system	**5.29** Information security during disruption **5.30** ICT readiness for business continuity
R10	A04 Cloud servers; A07 Staff login system	**5.15** Access control **8.2** Privileged access rights

> **Pattern:** 4 of the 10 risks (R1, R4, R5, R10) are about **who has access**. They map to Annex A 5.15–5.22, 8.2 and 8.5. That is why the policy in section 5 is the Access Control Policy.

5 Access Control Policy

DOCUMENT ID	VERSION	OWNER	APPROVER	CLASSIFICATION
NTP-POL-007	1.0	Security Manager	CTO	Internal

1. Purpose

To make sure only the right people can access NileTech systems and data, and only as much as their job needs. This protects card data and customer data and supports PCI DSS, Egypt's data protection law and ISO/IEC 27001.

2. Scope

All employees, contractors, interns and outside companies (including the outsourced developers and support team) who use any NileTech system: cloud servers, company email, business apps, laptops and the office network.

3. Roles and responsibilities

Role	Responsibility
Security Manager	Owns this policy; approves admin access; runs access reviews
System owners	Decide who needs what access to their system; approve requests; confirm access in reviews
Line managers	Request access for their team; tell HR about role changes and leavers on time
IT team	Give and remove access only from an approved request
HR	Record joiners, movers and leavers in the HR system on time
All users	Keep passwords secret; never share accounts; report anything suspicious

4. Policy statements

4.1 Basic rules

1. People **shall** only get the access they need for their job (least privilege).
2. Every person **shall** have their own account. Shared accounts are not allowed.

4.2 Getting access

3. Access **shall** be requested through an IT ticket and approved by the line manager and system owner **before** it is given.
4. Admin access **shall** also be approved by the Security Manager.

4.3 Logging in

5. Multi-factor authentication (MFA) **shall** be used for all company apps, remote access and admin accounts.
6. Admins and finance staff **shall** use physical security keys instead of phone approvals.
7. Passwords **shall** be at least 14 characters long.

4.4 Admin access

8. Admins **shall** use a separate admin account, not their everyday account.
9. Admin rights **shall** be given only when needed and expire after 8 hours. Permanent admin access is not allowed.
10. No more than 4 people **shall** hold full admin rights at any time.

4.5 Outside companies

11. Supplier staff **shall** each have their own named account, which expires after 90 days or at contract end, whichever is first.
12. Suppliers **shall not** have permanent access to live systems. Each access must be approved by the system owner.

4.6 Access reviews

13. Admin and supplier access **shall** be reviewed **every 3 months**; all other access every 6 months.
14. Access found unnecessary **shall** be removed within 5 working days.

4.7 Movers and leavers

15. All access **shall** be removed within **24 hours** of someone leaving, and immediately if they are dismissed.
16. When someone changes role, access they no longer need **shall** be removed within 5 working days.

4.8 Devices and logs

17. Company data **shall** only be accessed from laptops managed by IT.
18. Login records **shall** be kept for at least 12 months.

5. Exceptions

Anyone needing an exception fills in an exception form explaining why, what the risk is, and what extra protection will be used instead. The system owner and the Security Manager must both approve it. Exceptions last a maximum of **6 months**.

6. Compliance and enforcement

Compliance is checked through the access reviews, monthly reports (accounts without MFA, unused accounts, extra admins) and internal audit. Breaking this policy can lead to loss of access and disciplinary action, up to dismissal. Suppliers who break it can have their contract ended.

7. Related documents

Information Security Policy · Acceptable Use Policy · Joiners, Movers and Leavers Procedure · Supplier Security Policy · ISO/IEC 27001:2022 Annex A 5.15–5.18, 8.2, 8.5 · PCI DSS v4.0.1 Requirements 7 and 8.

8. Review and version history

Reviewed every year, or sooner after a major incident or company change.

Version	Date	Author	Approver	Change
0.1	14 Oct 2026	Ahmed Talaat	–	First draft
1.0	28 Oct 2026	Ahmed Talaat	CTO	Approved; supplier rules (4.5) added after risk R5

6 Executive summary

To: CEO, CTO, CFO · From: Ahmed Talaat, GRC · Date: 30 October 2026 · Subject: Security risk assessment results

BOTTOM LINE

Our biggest security problem is **too many people with powerful access**. Our outsourced developers have a permanent admin account on our cloud servers, and 14 of our own staff have full admin rights that nobody checks. We need **three decisions**, all doable within 90 days for an estimated **under USD 10,000**.

1	7	2	0	8 / 10
Critical	High	Medium	Low	too high

We looked at 17 key assets and 10 risks. Our current controls lower the average risk score from 17.4 to 11.9, but 8 risks are still above what the company is willing to accept.

Top 3 risks and the decisions we need

1 · R5 Outsourced developers with permanent admin access — 20 Critical

The 6 outsourced developers share one admin account on our cloud servers, and their contract has no security terms. If they get hacked, we get hacked, and card data could be exposed.

Decision: remove the shared account by 15 Dec 2026, give each developer their own approved access, and add security terms to the contract. Cost: staff time only.

2 · R1 Phishing leading to stolen accounts — 15 High

Phishing is the easiest way in. A stolen finance or admin email account could be used to redirect merchant payouts.

Decision: buy ~60 security keys for admins and finance (est. USD 3,500) and run monthly phishing tests. Owner: IT Manager, by 31 Mar 2027.

3 · R10 Too many admins — 15 High

14 people have full admin access and it has never been reviewed. One stolen admin account would give an attacker control of everything.

Decision: cut admins to 4, give admin rights only when needed (est. USD 3,500 per year for the tool), and review admin access every 3 months. Owner: Security Manager, by 31 Jan 2027.

Why these three together: they share one root cause, uncontrolled access, and the new Access Control Policy (section 5) fixes all three. It also closes gaps against PCI DSS Requirements 7 and 8 before our next card-security audit.

The other High risks (logging, updates, ransomware, public storage, disaster recovery) have owners and deadlines in the register and will be reported monthly. Costs are estimates.

7 Audit finding: admin access reviews

FINDING ID	RATING	AREA	RELATED RISKS
IA-2026-03	High	Access management	R10, R5

Condition	Admin access has not been reviewed in the last 12 months. Of the 14 admins on our cloud servers, 3 no longer need it and 1 is a former intern whose account is still active.
Criteria	ISO/IEC 27001:2022 Annex A 5.18 (access rights) and 8.2 (privileged access rights); PCI DSS v4.0.1 Requirement 7.2.4 (review access at least every 6 months); Access Control Policy section 4.6 (review every 3 months).
Cause	Nobody owns the review, and cloud admin accounts are created outside the single sign-on system, so they are missed when people leave.
Effect	Extra admin accounts make it easier for an attacker to get in; a forgotten account is an easy target. Likely to be raised in the next PCI DSS audit.
Recommendation	Remove the former intern's account and the 3 unneeded admins now; move all cloud logins to single sign-on; run a signed review every 3 months.
Management response	**Agreed.** Former intern's account removed 29 Oct 2026. The Security Manager owns the reviews; first signed review due 31 Jan 2027.

Project reflection

What I did	Built a risk assessment for a fictional 250-person payments company: 17 assets, 10 risks scored before and after controls on a 5×5 scale, mapped to ISO/IEC 27001:2022 Annex A, plus a policy, an executive summary and an audit finding.
Key insight	Supplier access was a bigger risk than I first thought. R5 went from 10 to 20 once I checked who actually had admin rights, which showed me a score is only as good as the evidence behind it.
Framework use	Mapped every risk to ISO 27001 Annex A, for example the supplier controls 5.19–5.22 for R5.
Next time	Put money estimates on the top 3 risks, and collect evidence of controls before scoring, not after.